1. Common Vulnerabilities in Popular Applications

- A vulnerability is a weakness in an application that may be exploited to affect its confidentiality, integrity, or availability.
- **Broken Access Control:** Occurs when users can access data or perform actions beyond their permissions. In an app, this could expose another user's profile, order, or account details.
- **Injection:** Happens when untrusted input is treated as a command or query. It may allow an attacker to read, change, or delete application data.
- **Authentication and Session Weaknesses:** Weak login controls or poorly protected sessions may allow account takeover or unauthorized access.
- **Security Misconfiguration:** Incorrect permissions, exposed administrative interfaces, or unsafe default settings may reveal sensitive information or create entry points for attackers.
- **Cryptographic Failures:** Sensitive information that is not properly encrypted or protected may be exposed during storage or transmission.

Application Security • Vulnerability Summary
Examples of possible impact
• Broken Access Control — unauthorized access to another user's information or actions.
• Injection — unauthorized reading or modification of application data.
• Authentication Weaknesses — account takeover or session misuse.
• Security Misconfiguration — exposure of internal information or services.
• Cryptographic Failures — disclosure of passwords, payment details, or personal data.
Impact: These weaknesses can lead to privacy violations, financial loss, service disruption, and loss of user trust.

2. Install and Configure Nessus Essentials

- Nessus is a vulnerability-scanning tool used to identify known security weaknesses, missing updates, and configuration issues on systems.
- Visit the official Tenable website and select the Nessus Essentials edition. Register using the required details and obtain the activation code if requested.
- Download the installer that matches your operating system: Windows or Linux.
- On Windows, run the downloaded installer and follow the setup wizard. On Linux, install the package using the instructions provided for the selected distribution.
- After installation, open the Nessus web interface using the local address displayed by the installer or service setup.
- Complete the initial setup, select Nessus Essentials when prompted, enter the activation code, create an administrator account, and sign in.

Nessus Essentials • Initial Setup
Product: Nessus Essentials
Installation steps
1. Download the installer from the official Tenable website.
2. Install Nessus on the Windows or Linux system.
3. Open the Nessus web interface in a browser.
4. Select Nessus Essentials and complete activation.
5. Create the administrator username and password.
6. Sign in to open the Nessus dashboard.
Dashboard: The dashboard provides access to scans, scan results, and vulnerability information.

3. Scan a Target System Using Nessus

- Open the Nessus dashboard and select **New Scan** to create a vulnerability scan.
- Choose the **Basic Network Scan** template. This template is suitable for a general vulnerability assessment of a network target.
- Enter a clear scan name and provide the IP address of your own laptop or an authorized test virtual machine in the target field.
- Review the scan settings and save the configuration. Start the scan and allow Nessus to complete its checks.
- Open the completed scan to review the discovered hosts, vulnerabilities, severity levels, and recommended remediation steps.
- Use the export option in the scan results to generate and save the report in PDF format.

Nessus • Basic Network Scan
Scan template: Basic Network Scan
Scan name: Laptop Vulnerability Assessment
Target: IP address of the authorized laptop or test virtual machine
Scan configuration
• Select the Basic Network Scan template.
• Enter the target device's IP address.
• Save the scan configuration and launch the scan.
Review results
Hosts discovered, vulnerability names, severity levels, affected services, and remediation recommendations.
Report: Export the completed scan results as a PDF file.

4. Comparison of Nessus and OpenVAS

- Nessus and OpenVAS are vulnerability-scanning tools used to identify security weaknesses in computers, servers, and network services.
- **1. Licensing and Availability:** Nessus is a commercial product from Tenable with an Essentials option. OpenVAS is an open-source vulnerability scanner available through the Greenbone community ecosystem.
- **2. Vulnerability Tests and Updates:** Nessus uses Tenable's vulnerability plugins and update system. OpenVAS uses the Greenbone Community Feed for vulnerability tests and related updates.
- **3. Setup and Management:** Nessus provides a web-based interface designed for scan configuration and result review. OpenVAS is commonly managed through the Greenbone Security Assistant web interface and may require more setup of its scanner and feed components.
- Both tools can scan authorized targets, classify vulnerabilities by severity, and provide information that helps administrators prioritize remediation.
- For a real-world application environment, the choice depends on licensing requirements, deployment preferences, update ecosystem, reporting needs, and available technical resources.

Nessus vs OpenVAS • Feature Comparison
Feature Nessus OpenVAS
Licensing Commercial; Essentials option Open-source community ecosystem
Vulnerability tests Tenable plugin feed Greenbone Community Feed
Management interface Nessus web interface Greenbone Security Assistant
Common capabilities
• Identify known vulnerabilities and exposed services.
• Display severity levels to help prioritize findings.
• Provide technical details and remediation guidance.
Conclusion: Nessus offers a Tenable-managed scanning platform, while OpenVAS provides an open-source alternative through the Greenbone ecosystem. Both are useful for authorized vulnerability assessments.